

WEBSITE SECURITY ASSESSMENT

Passive Observation Report — NexaStore Digital Marketplace

Internship Assignment

Prepared by: Akshat Arin Mazumdar

Role: Cybersecurity / Security Research (Intern)

Date: August 31, 2026

Target: NexaStore (self-built application, deployed on Vercel)

This report documents a passive, screenshot-based review of a self-developed web application's public-facing interface. It does not include active reconnaissance, network scanning, or exploitation activity, as no evidence of such testing was available at the time of writing.

Table of Contents

Table of Contents.....2

1. Executive Summary.....3

2. Purpose of the Assignment3

3. Scope and Authorization.....3

 Target.....3

 Assets Reviewed.....3

 Activity Performed4

 Authorization.....4

4. Methodology.....4

5. Tools Used.....4

6. Screenshot-by-Screenshot Evidence Analysis4

 Figure 1 — Homepage / Landing Page.....4

 Figure 2 — Product Listing ("Shop") Page5

 Figure 3 — Login / Authentication Page.....6

 Figure 4 — Terms of Service7

 Figure 5 — Privacy Policy8

 Figure 6 — Refund Policy.....9

 Figure 7 — Site Footer10

7. Recommendations for Further, Properly Scoped Testing.....11

8. Limitations.....12

9. Conclusion.....12

10. Appendix12

 A. Third-Party Services Disclosed by the Application12

 B. Published Contact Information13

 C. Figure Index13

1. Executive Summary

This report presents a review of NexaStore, a self-built digital product marketplace application deployed on Vercel by the author for the purpose of internship-related security learning. The review is based exclusively on seven screenshots captured directly from the live application's user interface.

Important scope clarification: the available evidence consists entirely of rendered web pages (homepage, product listing, login screen, and three legal/policy pages, plus the site footer). No terminal output, command-line tool results, DNS enumeration, WHOIS records, subdomain discovery output, or port/service scan data (e.g., Nmap) were provided or captured. Consequently, this document is scoped as a passive interface and content review, not a network or infrastructure reconnaissance report.

Key observations drawn strictly from the evidence include: the application's page structure and navigation, the technologies referenced in its own Privacy Policy (Razorpay, SendGrid, Cloudinary, and Neon PostgreSQL), the authentication flow offered to users (email/password plus Google and GitHub OAuth), and the contact/support information disclosed in the footer and Refund Policy.

No vulnerabilities were confirmed during this review. Where an item may warrant further, properly scoped technical testing (DNS lookups, active scanning, authentication testing, etc.), it is flagged in Section 8 (Limitations) and Section 7 (Recommendations for Further Testing) rather than reported as a finding.

2. Purpose of the Assignment

The broader goal of a reconnaissance-and-review exercise within a cybersecurity assessment is to build an accurate picture of a target application before any deeper technical testing is performed. Typical objectives include:

- Mapping the application's attack surface (pages, forms, entry points).
- Identifying the technology stack and third-party services in use.
- Understanding authentication and account-management flows.
- Reviewing publicly stated policies for data handling, security claims, and support channels.
- Collecting a baseline of information to guide further, properly authorized technical testing.

For this exercise, the target — NexaStore — is an application the author designed and deployed personally, which resolves any authorization concern: testing one's own deployed application does not require third-party permission.

3. Scope and Authorization

Target

NexaStore — a digital product marketplace web application, described by the author as self-built and deployed on Vercel.

Assets Reviewed

- Homepage / landing page
- Product ('Shop') listing page
- Login / authentication page
- Terms of Service page
- Privacy Policy page
- Refund Policy page
- Site footer (visible on the homepage capture)

Activity Performed

Passive visual review of the application's publicly accessible pages, as captured in the provided screenshots. No active scanning, automated tooling, credential testing, or exploitation was performed or evidenced.

Authorization

The author has stated that NexaStore is their own application, self-built and self-deployed on Vercel. This report treats that statement as the basis for authorization; no independent authorization document (e.g., a signed scope-of-work or pentest authorization letter) was provided, and none is claimed here beyond the author's ownership statement.

4. Methodology

Because the available evidence is limited to interface screenshots, the methodology for this specific report was necessarily limited to manual visual analysis rather than tool-driven reconnaissance:

Screenshot Collection → Page-by-Page Visual Analysis → Content & Feature Extraction → Cross-Referencing Third-Party Services Disclosed in Policies → Documentation of Observations → Identification of Gaps for Further Testing

This workflow is a substitute for, not equivalent to, a full reconnaissance methodology (which would normally include DNS enumeration, WHOIS lookup, subdomain discovery, and port/service scanning). Section 8 details the resulting limitations.

5. Tools Used

No command-line or automated reconnaissance tools are visible in, or were disclosed alongside, the provided evidence. The only "tool" evidenced in this review is direct manual browsing of the live application in a web browser.

Tool / Method	Purpose	Evidence
Web browser (manual navigation)	Capturing and reviewing the live application's UI	Figures 1–7

No DNS tools, WHOIS clients, subdomain enumeration tools, or network scanners (e.g., Nmap) are represented in the evidence provided.

6. Screenshot-by-Screenshot Evidence Analysis

Figure 1 — Homepage / Landing Page

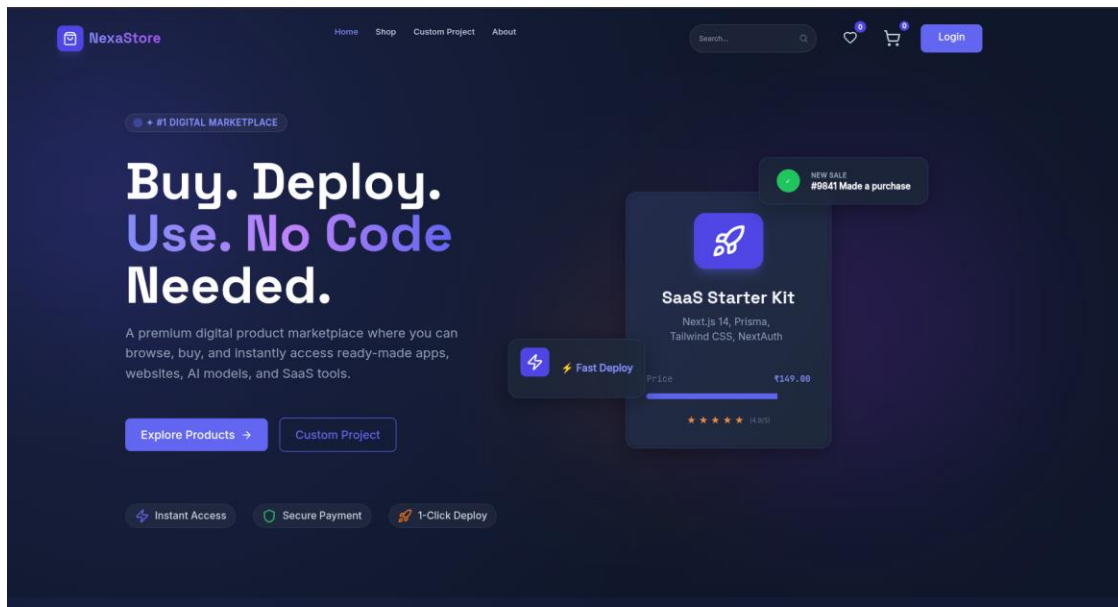


Figure 1: NexaStore homepage, showing hero section, navigation bar, and a sample product card.

What is visible:

The NexaStore homepage, including the top navigation bar (Home, Shop, Custom Project, About), a search field, wishlist and cart icons, a "Login" button, and a hero section with the tagline "Buy. Deploy. Use. No Code Needed." A sample product card for a "SaaS Starter Kit" (₹149.00, built with Next.js 14, Prisma, Tailwind CSS, NextAuth) is shown, along with a simulated "New Sale" notification and badges for "Instant Access," "Secure Payment," and "1-Click Deploy."

Command / Method:

None — direct browser navigation to the site's root URL.

Result:

The page renders as a marketing/landing page for a digital-product marketplace concept.

Security Relevance:

The product card text discloses part of the technology stack used in at least one listed product (Next.js 14, Prisma, Tailwind CSS, NextAuth). This is product-description content, not necessarily the stack of NexaStore itself, and should not be conflated with the marketplace platform's own backend.

Observation:

No credentials, tokens, or sensitive data are visible on this page.

Figure 2 — Product Listing ("Shop") Page

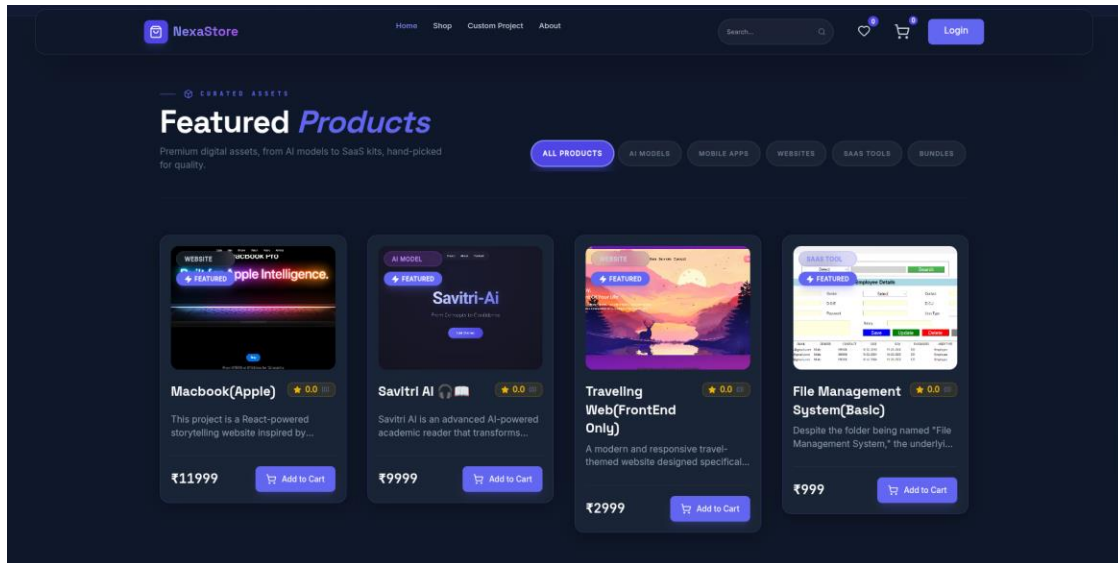


Figure 2: Featured Products grid showing category filters and four sample listings.

What is visible:

A "Featured Products" grid with category filter tabs (All Products, AI Models, Mobile Apps, Websites, SaaS Tools, Bundles). Four product cards are shown: "Macbook(Apple)" (₹11,999), "Savitri AI" (₹9,999), "Traveling Web(FrontEnd Only)" (₹2,999), and "File Management System(Basic)" (₹999), each with a category tag, a short description, a star rating placeholder (0.0), and an "Add to Cart" button.

Command / Method:

None — direct browser navigation to the Shop page.

Result:

Confirms the presence of a functioning product catalog and a client-side (or server-rendered) filtering/category system.

Security Relevance:

E-commerce-style pages of this kind typically involve server-side logic for cart state, pricing, and inventory. No such backend behavior is visible in this screenshot; only the rendered front end is evidenced.

Observation:

All ratings are shown as 0.0 (0 reviews), consistent with a newly deployed or demo catalog. No sensitive data is visible.

Figure 3 — Login / Authentication Page

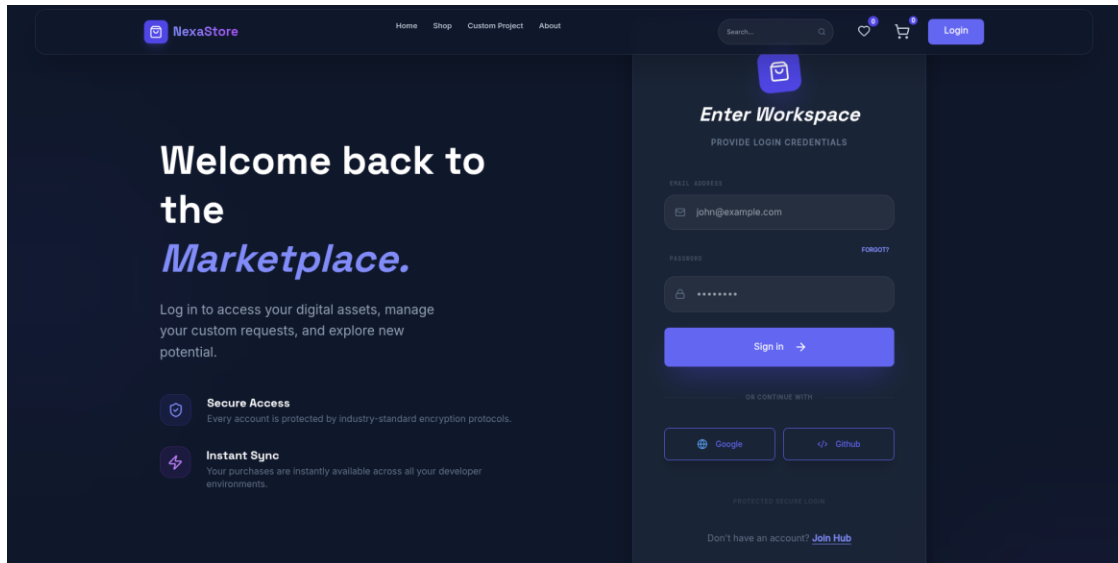


Figure 3: "Enter Workspace" login form with email/password fields and OAuth options.

What is visible:

A login page titled "Enter Workspace," with an email address field (placeholder: john@example.com), a masked password field, a "Forgot?" link, a "Sign in" button, and two OAuth options: "Google" and "Github." Two supporting feature callouts, "Secure Access" and "Instant Sync," describe encryption and cross-environment purchase sync. A "Join Hub" link is offered for account creation.

Command / Method:

None — direct browser navigation to the login route; no credentials were submitted or captured in this evidence.

Result:

Confirms the application supports both traditional email/password authentication and third-party OAuth (Google, GitHub).

Security Relevance:

Authentication pages are a primary attack surface (credential stuffing, brute force, OAuth misconfiguration, session handling). The screenshot alone does not reveal whether rate limiting, account lockout, multi-factor authentication, or secure session handling are implemented — these would require active, authorized testing to determine.

Observation:

No real credentials are visible; the email field shows placeholder text and the password field is masked. No secrets are exposed in this image.

Figure 4 — Terms of Service

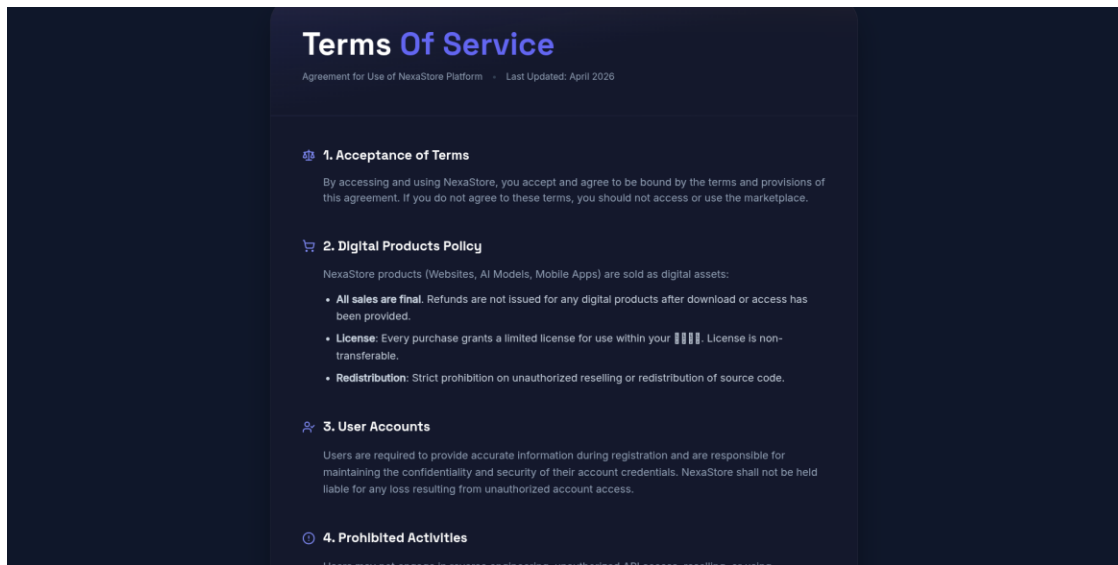


Figure 4: Terms of Service page, sections 1–4 (Acceptance of Terms, Digital Products Policy, User Accounts, Prohibited Activities).

What is visible:

The Terms of Service page, last updated April 2026, covering: acceptance of terms; a digital-products policy stating all sales are final and licenses are non-transferable; user-account responsibilities (users must safeguard their own credentials, and NexaStore disclaims liability for unauthorized account access arising from that); and the start of a "Prohibited Activities" section referencing reverse engineering and unauthorized API access.

Command / Method:

None — direct browser navigation.

Result:

Establishes the platform's stated policy on refunds, licensing, and acceptable use.

Security Relevance:

The explicit mention of "unauthorized API access" as a prohibited activity implies the platform exposes an API of some kind, though no API endpoints, routes, or documentation are visible in the provided evidence.

Observation:

One line of body text renders as garbled/placeholder characters (a font or encoding rendering artifact) in the License clause; this does not appear to be sensitive data, but the page content in that spot could not be fully read from the screenshot.

Figure 5 — Privacy Policy

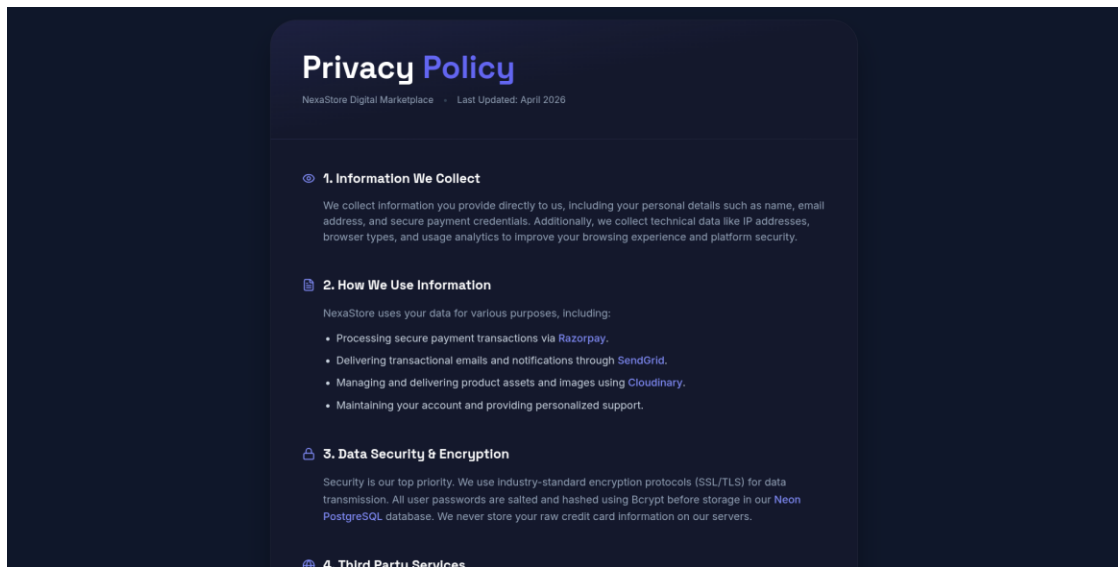


Figure 5: Privacy Policy page, sections 1–3 (Information We Collect, How We Use Information, Data Security & Encryption).

What is visible:

The Privacy Policy page (last updated April 2026), stating that the platform collects name, email, and payment credentials, plus technical data such as IP addresses, browser type, and usage analytics. It explicitly names four third-party services: Razorpay (payment processing), SendGrid (transactional email), Cloudinary (asset/image delivery), and Neon PostgreSQL (database). It also states that SSL/TLS is used for data in transit and that passwords are salted and hashed with Bcrypt before storage.

Command / Method:

None — direct browser navigation.

Result:

This is the single most information-dense screenshot in the evidence set from a technology-footprint perspective.

Security Relevance:

Publicly naming specific third-party infrastructure providers (payment gateway, email service, media CDN, database provider) is a form of technology disclosure. This is common and not inherently a vulnerability, but it does narrow the field for anyone attempting to target the platform's supply chain or look for provider-specific misconfigurations. The stated use of Bcrypt password hashing and TLS is a positive security practice as described in the policy text — this review has no independent evidence confirming these claims are correctly implemented.

Observation:

No credentials, API keys, or tokens are exposed in this screenshot — only the names of the third-party service providers, which the platform itself has chosen to disclose publicly.

Figure 6 — Refund Policy



Figure 6: Refund Policy page, sections 1–3 (No Refund Policy, Policy Exceptions, How to Request & Resolution).

What is visible:

The Refund Policy page (last updated April 2026), stating a general no-refund policy with three named exceptions (broken asset, incorrect product, duplicate transaction), and instructions to email nexastore.hq@gmail.com within 48 hours of purchase with an Order ID to request a refund.

Command / Method:

None — direct browser navigation.

Result:

Confirms a publicly listed contact email used for support/refund requests.

Security Relevance:

A directly published contact email is a normal, expected element of a commercial site's support process. It also represents a potential target for phishing or social-engineering attempts impersonating the platform, which is worth noting as an awareness point rather than a technical vulnerability.

Observation:

The email address nexastore.hq@gmail.com is displayed in plain text on a public page; this is intentional, user-facing contact information, not a leaked secret, but it is flagged here per the reporting instructions to note any potentially sensitive information visible in evidence.

Figure 7 — Site Footer

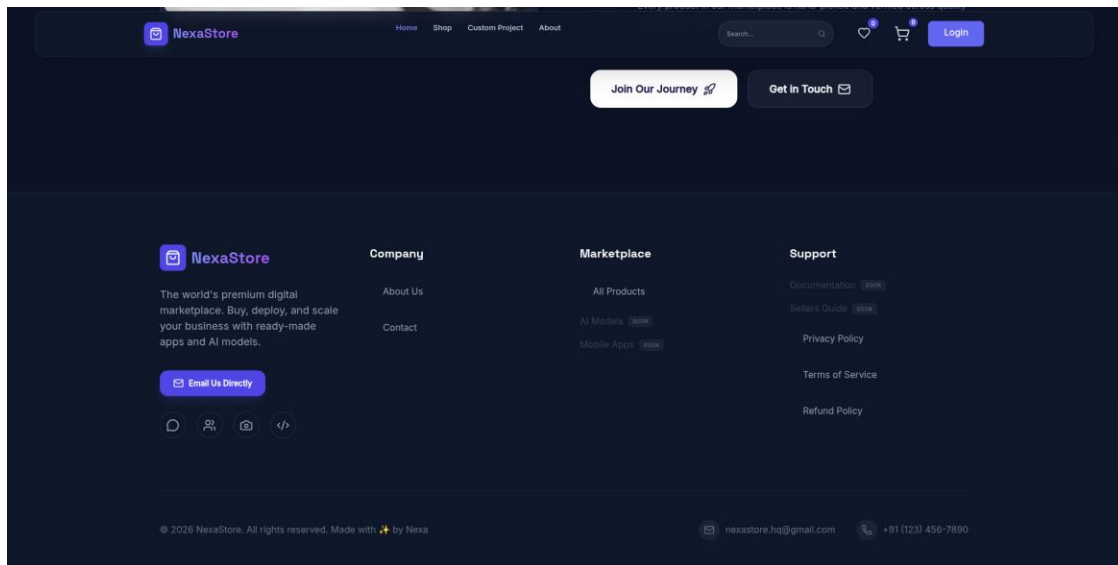


Figure 7: Homepage footer, showing site map links, contact details, and copyright information.

What is visible:

The footer region of the homepage, containing: call-to-action buttons ("Join Our Journey," "Get in Touch"); a site map organized into "Company" (About Us, Contact), "Marketplace" (All Products, plus AI Models and Mobile Apps marked "Soon"), and "Support" (Documentation and Sellers Guide marked "Soon," plus live links to Privacy Policy, Terms of Service, and Refund Policy); social/contact icons; and a copyright line reading "© 2026 NexaStore. All rights reserved. Made with ✨ by Nexa," alongside a duplicate listing of the contact email (nexastore.hq@gmail.com) and a phone number (+91 (123) 456-7890).

Command / Method:

None — direct browser navigation.

Result:

Confirms the site's information architecture (which sections exist, which are live vs. planned) and its published contact channels.

Security Relevance:

The "Soon" labels on AI Models, Mobile Apps, Documentation, and Sellers Guide indicate the platform is under active development, with several planned sections not yet live. This is a useful scoping note: an attack surface review performed later, once those sections launch, would need to be revisited.

Observation:

A phone number and email address are published in plain text, consistent with normal business contact disclosure on a commercial site footer.

7. Recommendations for Further, Properly Scoped Testing

The following activities were not performed as part of this review (no supporting evidence was available) but would normally follow a passive review of this kind, since NexaStore is the author's own application and can be tested directly:

- DNS enumeration (dig, nslookup) against the Vercel-assigned domain to document A/AAAA, CNAME, MX, NS, and TXT records.
- WHOIS lookup on the registered domain to review registration and ownership metadata.

- Passive/active subdomain discovery (e.g., subfinder, amass) to identify any additional exposed subdomains beyond the primary application.
- Port and service enumeration (e.g., nmap -sV) against the resolved IP address(es), noting that Vercel-hosted applications are typically served through a shared CDN/edge network, which affects how a scan should be interpreted.
- Authenticated review of the login flow for rate limiting, account lockout, and multi-factor authentication support.
- Verification of the security claims stated in the Privacy Policy (TLS configuration, password hashing) using appropriate tooling, rather than relying on the policy text alone.

Performing and documenting these steps would allow the report to be upgraded from a passive interface review into a genuine reconnaissance report matching the original assignment structure.

8. Limitations

- No terminal, command-line, or tool output was provided; all technical-reconnaissance sections of a standard recon report (DNS, WHOIS, subdomains, port/service scanning) could not be completed.
- No IP addresses were captured or provided in the evidence, so infrastructure/hosting analysis is limited to the author's statement that the application is deployed on Vercel.
- Technology-stack information is limited to what the application itself discloses in its own text (Privacy Policy service names, one product's description); no independent verification (e.g., via HTTP headers or fingerprinting tools) was performed.
- One line of text in the Terms of Service screenshot (Figure 4) rendered as unreadable placeholder characters and could not be interpreted.
- This review is passive only; no forms were submitted, no authentication was attempted, and no requests beyond normal page navigation were made or evidenced.

9. Conclusion

This review documented the publicly visible structure, content, and disclosed technology footprint of NexaStore based on seven interface screenshots. It confirmed the application's page architecture, its stated third-party service providers (Razorpay, SendGrid, Cloudinary, Neon PostgreSQL), its dual authentication model (email/password and OAuth), and its published support contact channels.

No reconnaissance-tool evidence (DNS, WHOIS, subdomain, or port-scan data) was available, so this report does not make claims in those areas. To produce the full reconnaissance report originally scoped for this assignment, the author should perform the activities listed in Section 7 against their own Vercel-deployed instance and capture the corresponding terminal output as evidence.

10. Appendix

A. Third-Party Services Disclosed by the Application

Service	Stated Purpose (per Privacy Policy)
Razorpay	Processing secure payment transactions
SendGrid	Delivering transactional emails and notifications
Cloudinary	Managing and delivering product assets and images

Service	Stated Purpose (per Privacy Policy)
Neon PostgreSQL	Primary application database

B. Published Contact Information

Channel	Value	Source
Support / Refund email	nexastore.hq@gmail.com	Figures 6 & 7
Phone number	+91 (123) 456-7890	Figure 7

C. Figure Index

Figure	Title
Figure 1	Homepage / Landing Page
Figure 2	Product Listing ("Shop") Page
Figure 3	Login / Authentication Page
Figure 4	Terms of Service
Figure 5	Privacy Policy
Figure 6	Refund Policy
Figure 7	Site Footer